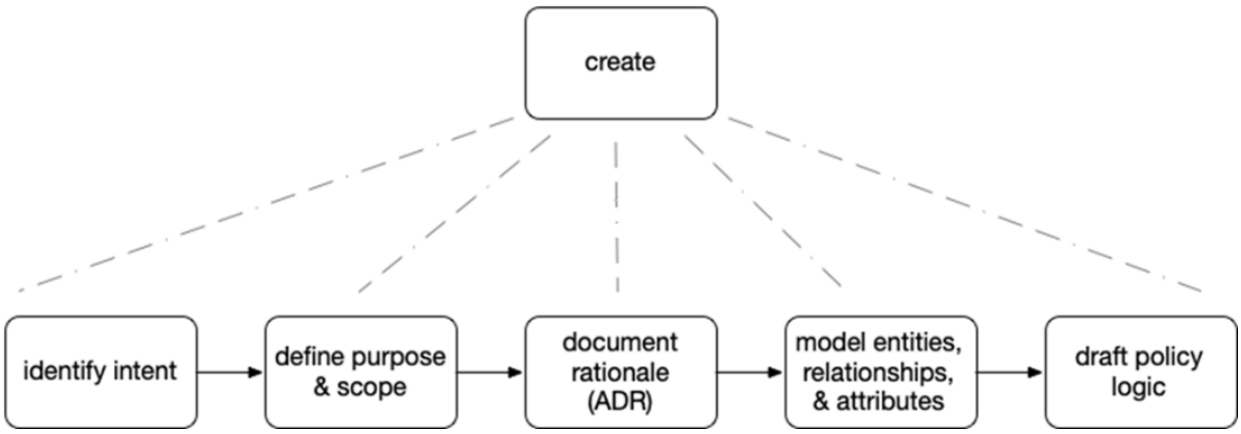


Figure 14.3 Policy creation as a governance process. The create stage of the policy lifecycle expands into a sequence of governance steps. Policy authors begin by identifying intent, defining purpose and scope, and documenting rationale in an Architectural Decision Record (ADR). Only after entities and attributes are modeled is authorization logic drafted, ensuring that every policy reflects deliberate organizational intent.

The aim is not just to write code but also to record a statement of organizational will: why this rule exists and what principle it enforces.

14.2.2 Review and approve

Before a policy can influence real decisions, it must gain legitimacy. Governance determines who reviews policies, what criteria they use, and how approval is documented. Reviews include both human and automated checks: static analysis, schema validation, test-case coverage, and peer review. Compliance officers confirm alignment with regulations, while system administrators ensure consistency with existing policies. Approval turns a draft from a proposal into an endorsed statement of the organization’s intent.

14.2.3 Deploy and use

Once approved, the policy is versioned, published to the PAP, and distributed to the PDPs, where the policies become operational. This is where policy governance intersects with policy as code: CI/CD pipelines manage deployment, change control maintains version integrity, and automated tests verify that new policies do not disrupt existing decisions. At this stage, governance ensures operational discipline, ensuring that policies behave as expected in production, under real workloads.